



PRESIDENCY UNIVERSITY

Private University Estd. in Karnataka State by Act No. 41 of 2013
Itgalpura, Rajankunte, Yelahanka, Bengaluru – 560064



Third-Party Risk Management in Finance: Frameworks & Assessment

AN INTERNSHIP REPORT

Submitted by

ABDUL AZEEM – 20221CCS0072

Under the guidance of,

Dr. Vijaya Kumar A V

BACHELOR OF TECHNOLOGY

IN

**COMPUTER SCIENCE AND ENGINEERING
(CYBER SECURITY)**



PRESIDENCY UNIVERSITY

BENGALURU

APRIL 2026



PRESIDENCY UNIVERSITY

Private University Estd. in Karnataka State by Act No. 41 of 2013
Italgapura, Rajankunte, Yelahanka, Bengaluru - 560064



PRESIDENCY SCHOOL OF COMPUTER SCIENCE AND ENGINEERING (CYBER SECURITY) BONAFIDE CERTIFICATE

Certified that this internship report titled "**Third-Party Risk Management in Finance: Frameworks & Assessment**" is a bonafide record of work carried out by **Abdul Azeem (20221CCS0072)** in partial fulfilment of the requirements for the award of the Degree of **BACHELOR OF TECHNOLOGY in COMPUTER SCIENCE AND ENGINEERING (CYBER SECURITY)** at Presidency University, Bengaluru, during the academic year 2025-2026.

Dr. Vijaya Kumar A V

Associate Professor
Internship Guide
PSCS, Presidency University

Dr. Geetha A

Associate Professor
Programme Internship
Coordinator
PSCS, Presidency University

Dr. Geetha A

Associate Professor
School Internship Coordinator
PSCS, Presidency University

Dr. Anandaraj S.P

Professor & Head of Department
PSCS, Presidency University

Dr. Shakkeera L

Associate Dean
PSCS, Presidency University

Sl. No.	Name of the Examiner	Signature
1.	Dr. Sindhu S	 24/4/2026
2.	Dr. Srabana Pramanik	 24/4/26



PRESIDENCY UNIVERSITY

Private University Estd. in Karnataka State by Act No. 41 of 2013
Itgalpura, Rajankunte, Yelahanka, Bengaluru – 560064



PRESIDENCY SCHOOL OF COMPUTER SCIENCE AND ENGINEERING (CYBER SECURITY)

DECLARATION

I am a student of final year B.Tech in Computer Science and Engineering (Cyber Security), at Presidency University, Bengaluru, named **Abdul Azeem**, hereby declare that the internship work titled “**Third-Party Risk Management in Finance: Frameworks & Assessment**” has been independently carried out by me and submitted in partial fulfillment for the award of the Degree of BACHELOR OF TECHNOLOGY in COMPUTER SCIENCE AND ENGINEERING (CYBER SECURITY) during the academic year of 2025-2026. Further, the matter embodied in the internship has not been submitted previously by anybody for the award of any Degree or Diploma to any other institution.

Abdul Azeem

USN:20221CCS0072

Signature

Place: Bengaluru

Date: 24 April 2026

ACKNOWLEDGEMENTS

For completing this internship work, I have received the support and the guidance from many people whom I would like to mention with deep sense of gratitude and indebtedness. I extend my gratitude to our beloved **Chancellor, Pro-Vice Chancellor, and Registrar** for their support and encouragement in completion of the internship.

I would like to sincerely thank my internal guide **Dr. Vijaya Kumar A V**, Associate Professor Presidency School of Computer Science and Engineering, Presidency University, for his moral support, motivation, timely guidance and encouragement provided to me during the period of internship work.

I am also thankful to **Dr. Anandaraj S.P, Professor, Head of the Department, Presidency School of Computer Science and Engineering** Presidency University, for his mentorship and encouragement.

I express my cordial thanks to **Dr. Shakkeera L**, Associate Dean, Presidency School of Computer Science and Engineering and the Management of Presidency University for providing the required facilities and intellectually stimulating environment that aided in the completion of my internship work.

I am grateful to **Dr. Geetha A**, School Internship Coordinator and Program Internship Coordinator, Presidency School of Computer Science and Engineering, for facilitating problem statements, coordinating reviews, monitoring progress, and providing their valuable support and guidance.

I am also grateful to Teaching and Non-Teaching staff of Presidency School of Computer Science and Engineering and also staff from other departments who have extended their valuable help and cooperation.

Abdul Azeem

ABSTRACT

This report documents a six-month internship at KPMG Global Services, Bengaluru, from December 1, 2025 to May 29, 2026, as part of the final year B.Tech programme in Computer Science and Engineering (Cyber Security) at Presidency University. The internship was undertaken in the Third Party Risk Management (TPRM) practice — a discipline that enables organisations to identify, assess, treat, and govern risks arising from external vendors and service providers.

The programme comprised two phases: a two-week foundation training in cybersecurity, networking, IAM, security operations, GRC, and productivity tools; followed by a six-week TPRM specialisation covering enterprise risk frameworks, vendor due diligence, risk assessment and scoring, continuous monitoring, contractual governance, and automation in TPRM. All learning was consolidated in a capstone project — a full end-to-end TPRM engagement simulation for a fictional banking institution, Celestia National Bank Limited, assessing a cloud vendor, ApexNimbus Cloud Services, for Tier-1 Core and Mobile Banking workloads.

The capstone encompassed vendor criticality assessment, due diligence using SIG and CAIQ instruments, ISO/IEC 27001:2022 Annex A control mapping, a ten-risk risk register, risk treatment planning, MSA/DPA/SLA design, and a KRI-based continuous monitoring framework. The report provides substantial exposure to ISO 27001, ISO 27005, ISO 31000, ISO 27701, NIST CSF, GDPR, and the DPDP Act, 2023.

TABLE OF CONTENTS

Chapter / Section	Title	Page
	Declaration	iii
	Bonafide Certificate	ii
	Acknowledgements	v
	Abstract	vi
	List of Figures	x
	List of Tables	xi
	Abbreviations	xii
1	Introduction	1
1.1	Background	1
1.2	Internship Statistics	2
1.3	Prior Existing Technologies	2
1.4	Proposed Approach	2
1.5	Objectives	3
1.6	SDGs	3
1.7	Overview of Internship Report	3
2	Literature Review	5
2.1	ISO/IEC 27001:2022	5
2.2	ISO/IEC 27005:2022	5

2.3	ISO 31000:2018	5
2.4	ISO/IEC 27701:2019	6
2.5	NIST CSF 2.0	8
2.6	GDPR and DPDP Act	6
3	Methodology	7
3.1	Three Lines of Defence Model	7
3.2	Vendor Lifecycle Framework	7
3.3	Risk Assessment Methodology	8
3.4	Due Diligence Instruments	9
4	Project Management	11
4.1	Foundation Training – Weeks 1 and 2	11
4.2	TPRM Specialisation Training – Weeks 3 to 8	12
4.3	Milestone Assessments and Timeline	14
5	Analysis and Design – Capstone TPRM Engagement	15
5.1	Engagement Overview and Objectives	15
5.2	Criticality Assessment	16
5.3	Phase 1 – Sourcing and Pre-Contract Due Diligence	16
5.4	Phase 2 – Deep Risk Assessment	18
5.5	Risk Register and Treatment Plan	19
5.6	Phase 3 – Contracting and Monitoring Framework	21
5.7	Final Recommendation	23

6	Software and Tools	24
6.1	Tools Studied During Training	24
6.2	Tools Applied in Capstone	25
7	Evaluation and Results	26
7.1	Control Domain Scoring	26
7.2	Residual Risk Conclusion	27
7.3	Final Recommendation Summary	27
7.4	KRI Dashboard	27
8	Social, Legal, Ethical and Sustainability Aspects	29
9	Conclusion	31
	References	33
	Appendix	47

LIST OF FIGURES

Figure No.	Caption	Page
Figure 3.1	Three Lines of Defence Model	7
Figure 3.2	Vendor Lifecycle Framework – End to End	8
Figure 3.3	Risk Assessment Stages – ISO 27005:2022 Aligned	9
Figure 4.1	Internship Timeline – December 2025 to May 2026	14
Figure 5.1	Capstone Engagement – Three Phase Structure	15
Figure 5.2	Risk Heat Map – Capstone Risk Register (10 Risks)	20
Figure 7.1	Vendor Performance Dashboard – KRI Summary (RAG)	40

LIST OF TABLES

Table No.	Caption	Page
Table 1.1	Internship Statistics Summary	1
Table 4.1	Foundation Training Coverage – Weeks 1 and 2	11
Table 4.2	TPRM Specialisation Training – Week-by-Week Summary	12
Table 4.3	Milestone Assessment Structure	14
Table 5.1	Criticality Assessment Parameters	16
Table 5.2	Vendor Evaluation Scoring – ApexNimbus vs StratoSure	17
Table 5.3	Phase 1 Sourcing Summary	17
Table 5.4	Due Diligence Instruments Summary	18
Table 5.5	Risk Register – 10 Identified Risks	19
Table 5.6	Risk Treatment Plan – 10 Actions	21
Table 5.7	Contract Summary – MSA / DPA / SLA	22
Table 5.8	Ongoing Monitoring – KRIs and Cadence	22
Table 7.1	Control Domain Scoring Summary	26
Table 7.2	KRI Threshold Definitions	40

ABBREVIATIONS

Abbreviation	Full Form
AES	Advanced Encryption Standard
BYOK	Bring Your Own Key
CAIQ	Consensus Assessment Initiative Questionnaire
DLP	Data Loss Prevention
DPA	Data Processing Agreement
DPDP Act	Digital Personal Data Protection Act, 2023
DR	Disaster Recovery
ERM	Enterprise Risk Management
GDPR	General Data Protection Regulation
GRC	Governance, Risk and Compliance
HSM	Hardware Security Module
IAM	Identity and Access Management
ISO	International Organisation for Standardisation
KPI	Key Performance Indicator
KRI	Key Risk Indicator
MFA	Multi-Factor Authentication
MSA	Master Services Agreement
NIST CSF	National Institute of Standards and Technology Cybersecurity Framework

PAM	Privileged Access Management
PCI-DSS	Payment Card Industry Data Security Standard
PII	Personally Identifiable Information
QBR	Quarterly Business Review
RPO	Recovery Point Objective
RTO	Recovery Time Objective
SIG	Standardised Information Gathering
SIEM	Security Information and Event Management
SLA	Service Level Agreement
SOC	System and Organisation Controls
TLS	Transport Layer Security
TPRM	Third Party Risk Management

CHAPTER 1:

INTRODUCTION

1.1 Background

In the contemporary digital economy, organisations rely extensively on external vendors, cloud providers, and third-party processors to deliver core business functions. This creates a category of risk — third-party risk — that, if unmanaged, can lead to data breaches, regulatory penalties, operational disruptions, and reputational damage. Third Party Risk Management (TPRM) is the structured discipline through which organisations identify, assess, treat, and continuously monitor these risks.

TPRM is particularly critical in regulated industries such as banking and financial services, where failures by a single critical vendor can cascade across customer services and financial systems. Regulators globally — including the Reserve Bank of India (RBI), the European Banking Authority (EBA), and the Basel Committee — have mandated robust vendor risk governance programmes. India's Digital Personal Data Protection Act (DPDP Act, 2023) and the EU's GDPR further reinforce legal obligations for organisations and their data-processing third parties.

The internship at KPMG Global Services provided an immersive, structured environment to understand and practise TPRM within a Big Four professional services context. KPMG Global Services (KGS) is a global capability centre supporting KPMG member firms and their clients across advisory, audit, and technology-enabled services, with a strong TPRM practice serving financial services clients.

1.2 Internship Statistics

Parameter	Details
Intern Name	Abdul Azeem
USN	20221CCS0072
University	Presidency University, Bengaluru

Programme	B.Tech – Computer Science and Engineering (Cyber Security)
Organisation	KPMG Global Services, Bengaluru
Department / Practice	Third Party Risk Management (TPRM)
Duration	December 1, 2025 – May 29, 2026 (Six months)
Industry Guide / PM	Mr. Alex Jaideep, TPRM, KPMG Global Services
Foundation Training	Weeks 1–2 (12 days, ~60 hours)
TPRM Specialisation Training	Weeks 3–8 (30 days, ~240 hours)
Capstone Project	End-to-End TPRM Engagement Simulation (Week 8)
Milestone Assessments	7 (one per training week)

1.3 Prior Existing Technologies

Prior to formalised TPRM programmes, organisations managed vendor risk through ad-hoc contract reviews, informal security questionnaires, and periodic manual audits — approaches that lacked consistency, coverage, and integration with enterprise risk management, leaving significant gaps particularly for critical digital service providers.

The TPRM technology landscape has evolved through several generations. First-generation approaches used spreadsheet-based risk registers and email-distributed questionnaires with manual scoring. Second-generation approaches introduced dedicated GRC platforms such as RSA Archer IRM and MetricStream, enabling workflow automation and centralised evidence collection. Third-generation approaches — current best practice — integrate continuous external security ratings (BitSight, UpGuard, SecurityScorecard), real-time threat intelligence, and AI-assisted risk scoring into unified platforms such as ServiceNow VRM. In parallel, the standards landscape has matured: ISO 27001:2022 expanded supplier relationship controls across Annex A; ISO 27005:2022 aligned more closely with ISO 31000; and NIST CSF 2.0 (2024) added an explicit Govern function for supply chain risk management oversight.

1.4 Proposed Approach

The approach adopted in this internship is a structured, lifecycle-based TPRM methodology aligned with internationally recognised standards. Rather than treating vendor risk as a point-in-time compliance exercise, it treats TPRM as a continuous, integrated governance function — from vendor identification and inherent risk rating, through due diligence and onboarding, to ongoing monitoring and offboarding.

The practical application of this approach was demonstrated through the capstone project — a full end-to-end TPRM engagement simulation for a fictional banking institution (Celestia National Bank Limited) assessing a fictional cloud vendor (ApexNimbus Cloud Services) for Tier-1 workload hosting. The simulation applied ISO 27005:2022 risk assessment methodology, SIG and CAIQ due diligence instruments, ISO 27001:2022 Annex A control mapping, risk register and treatment planning, MSA/DPA/SLA contractual governance, and a KRI-based continuous monitoring framework — representing current best-practice TPRM in the financial services sector.

1.5 Objectives

The internship was undertaken with the following objectives:

1. Understand the operational foundations of TPRM and GRC in a Big Four advisory environment.
2. Gain proficiency in ISO 27001, ISO 27005, ISO 31000, ISO 27701, and NIST CSF frameworks.
3. Develop skills in vendor due diligence, risk scoring, and risk register management.
4. Learn continuous monitoring, KRI design, and contractual governance across MSA, DPA, and SLA instruments.
5. Apply all competencies in a full end-to-end capstone TPRM engagement simulation producing professional deliverables.

1.6 SDGs

The internship aligns with SDG 8 (Decent Work and Economic Growth) — building resilient vendor ecosystems that underpin stable economic performance; SDG 9 (Industry, Innovation and Infrastructure) — through application of automation and AI in TPRM; SDG 16 (Peace, Justice and Strong Institutions) — through transparent, evidence-based vendor governance and regulatory compliance; and SDG 17 (Partnerships for the Goals) — promoting accountable and

sustainable inter-organisational partnerships governed by robust contractual and monitoring frameworks.

1.7 Overview of Internship Report

Chapter 2 reviews the primary international standards and regulatory frameworks underpinning TPRM. Chapter 3 describes the core methodologies applied. Chapter 4 details the training structure, milestone assessments, timeline, and budget. Chapter 5 presents the full capstone engagement simulation. Chapter 6 covers tools studied and applied. Chapter 7 presents key findings and outcomes. Chapter 8 covers social, legal, ethical, sustainability, and safety aspects. Chapter 9 provides a reflective conclusion. References and Appendices follow.

CHAPTER 2:

LITERATURE REVIEW

2.1 ISO/IEC 27001:2022

ISO/IEC 27001:2022 is the international standard for Information Security Management Systems (ISMS). The 2022 revision restructured Annex A into 93 controls across four categories: organisational, people, physical, and technological. Of direct relevance to TPRM are Annex A.5 (organisational controls, including supplier relationship policies — A.5.19 through A.5.22), Annex A.6 (roles and responsibilities in supplier engagements), and A.8 (technology controls governing supplier access and data protection). The standard establishes requirements for supplier selection, contractual security obligations, ongoing monitoring, and handling of deviations — forming the normative foundation for TPRM programme design. ISO 27001 certification is increasingly a contractual and regulatory requirement for vendors in the financial services sector.

2.2 ISO/IEC 27005:2022

ISO/IEC 27005:2022 provides guidelines for information security risk management, aligned with ISO 27001 and ISO 31000. It defines a structured risk assessment process: Risk Identification (identifying risk sources and events), Risk Analysis (assessing likelihood and impact using qualitative or semi-quantitative models), Risk Evaluation (comparing risk levels against the organisation's risk appetite), and Risk Treatment (selecting Mitigate, Accept, Transfer, or Avoid options and designing treatment plans). ISO 27005 provides the methodological basis for vendor risk scoring and treatment planning applied in TPRM engagements.

2.3 ISO 31000:2018

ISO 31000:2018 provides principles and generic guidelines for risk management applicable to any organisation. It establishes the risk management process — context establishment, risk assessment, risk treatment, monitoring and review, and communication — as the overarching framework within which ISO 27005 methodology is embedded. In TPRM, ISO 31000 informs the governance philosophy: that risk management should be integrated, structured, evidence-based, and continuously reviewed rather than treated as a point-in-time activity.

2.4 ISO/IEC 27701:2019

ISO/IEC 27701:2019 extends ISO 27001 and ISO 27002 with requirements for a Privacy Information Management System (PIMS). It addresses both PII controllers and PII processors, placing specific obligations on vendors processing personal data: implementing appropriate technical and organisational security measures, processing PII only per documented instructions, disclosing sub-processors, and supporting data subject rights. In the capstone project, ISO 27701 obligations directly informed the design of DPA provisions around data residency, sub-processor management, and breach notification.

2.5 NIST Cybersecurity Framework 2.0

The NIST CSF 2.0 (2024) provides a policy framework for managing cybersecurity risk across six functions: Govern, Identify, Protect, Detect, Respond, and Recover. The addition of the Govern function in version 2.0 reflects the increased emphasis on cybersecurity governance and leadership oversight. In TPRM, the Identify function — particularly the supply chain risk management categories — provides specific guidance on assessing cybersecurity risks in supplier relationships. NIST CSF is widely adopted in the financial sector as a complement to ISO 27001.

2.6 GDPR and DPDP Act

The General Data Protection Regulation (GDPR, 2018) imposes binding obligations for data protection across EU data subjects. Article 28 requires that all data processing by a third-party processor be governed by a written Data Processing Agreement specifying the nature, purpose, duration, and security requirements of processing. India's Digital Personal Data Protection Act (DPDP Act, 2023) establishes equivalent obligations for data fiduciaries and processors in India, requiring data minimisation, purpose limitation, storage limitation, and security safeguards. Both instruments directly shaped the DPA design in the capstone project, particularly for data residency, sub-processor controls, and breach notification requirements.

CHAPTER 3:

METHODOLOGY

3.1 Three Lines of Defence Model

The Three Lines of Defence (3LoD) model defines the roles and responsibilities of different organisational functions in managing risk and maintaining internal controls. It provides the governance structure within which TPRM operates:

- **Line 1 – Business Operations:** Business units own and manage third-party risks arising from their direct vendor relationships. They initiate engagements, provide business context for criticality assessments, and implement agreed risk treatments.
- **Line 2 – Risk and Compliance:** The TPRM function sits in the second line. It designs and maintains the vendor risk framework, executes due diligence assessments, manages the risk register, and monitors vendor performance. GRC and information security functions also operate in Line 2.
- **Line 3 – Internal Audit:** Provides independent assurance over the adequacy and effectiveness of Line 1 and Line 2 controls, reviewing the TPRM programme periodically against its design and risk management objectives.

Understanding the 3LoD model is essential for effective TPRM programme design, clarifying ownership, escalation paths, and accountability for vendor risk across the organisation.

Figure 3.1 below illustrates the Three Lines of Defence model as applied in a TPRM context.

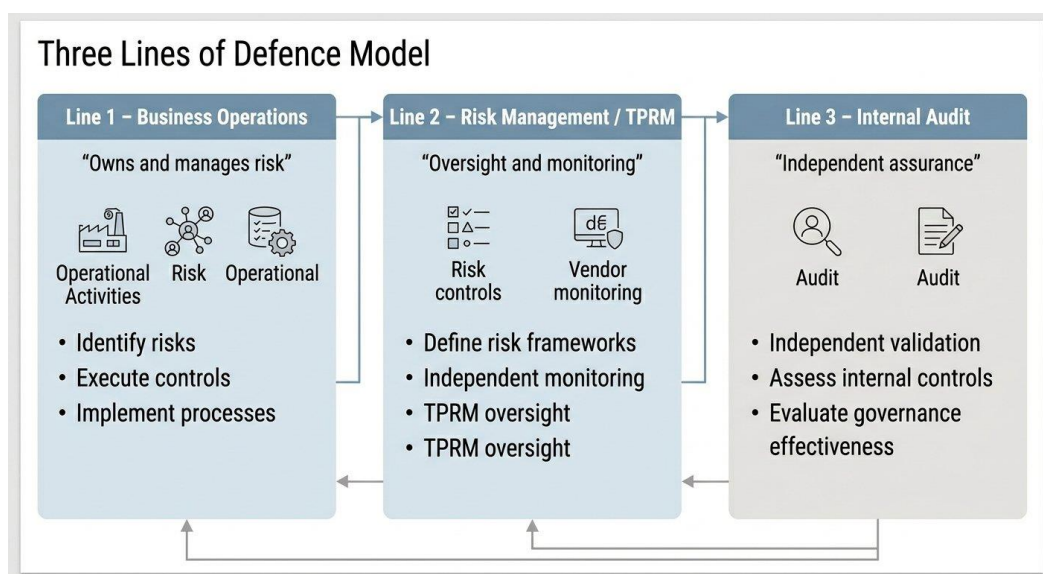


Figure 3.1 – Three Lines of Defence Model

3.2 Vendor Lifecycle Framework

The vendor lifecycle framework defines the end-to-end process for managing third-party vendor relationships, from identification through to offboarding. It comprises five stages: (1) Vendor Identification and Scoping — defining engagement scope, data classification, and regulatory context; (2) Inherent Risk Rating — scoring the vendor based on service type, data sensitivity, access level, and geography before any controls are assessed; (3) Due Diligence — conducting structured questionnaire-based assessments, reviewing vendor documentation, and performing control testing; (4) Ongoing Monitoring — continuously tracking vendor security posture, SLA performance, and KRI thresholds through defined review cadences; and (5) Offboarding — ensuring secure data recovery, access revocation, and fulfilment of contractual exit obligations. The framework also incorporates trigger points for enhanced due diligence when material changes occur in the vendor relationship.

Figure 3.2 illustrates the vendor lifecycle framework end to end.

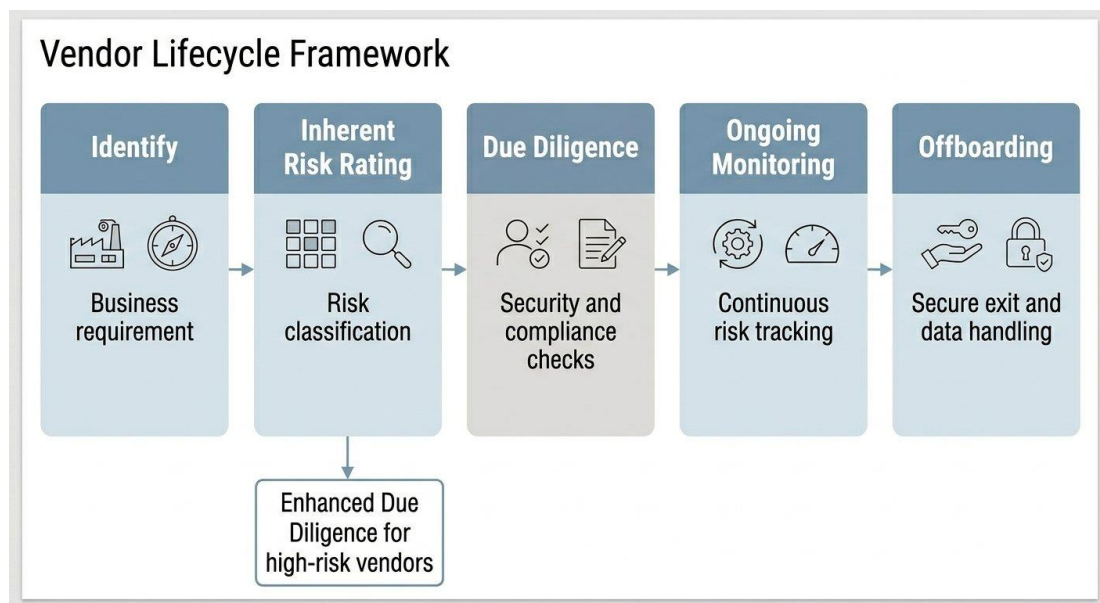


Figure 3.2 – Vendor Lifecycle Framework (End to End)

3.3 Risk Assessment Methodology

The risk assessment methodology applied in TPRM follows ISO/IEC 27005:2022 across four stages:

6. Risk Identification: Defining vendor engagement scope, collecting vendor data on services and data flows, and identifying potential risk events across key control domains.

7. Risk Analysis: Assessing each identified risk using a likelihood-impact model. Likelihood is based on control maturity and external signals; impact is based on business, regulatory, financial, and reputational consequences. The combination produces an inherent risk score on a 5x5 probability-impact matrix.
8. Risk Evaluation: Comparing assessed risk scores against the organisation's risk appetite. A risk heat map visually represents the distribution of identified risks, highlighting critical and high priorities for treatment.
9. Risk Treatment: Selecting and documenting treatment options — Mitigate, Accept, Transfer, or Avoid — for each risk requiring action, with assigned owners and target timelines.

Figure 3.3 illustrates the four-stage risk assessment process.

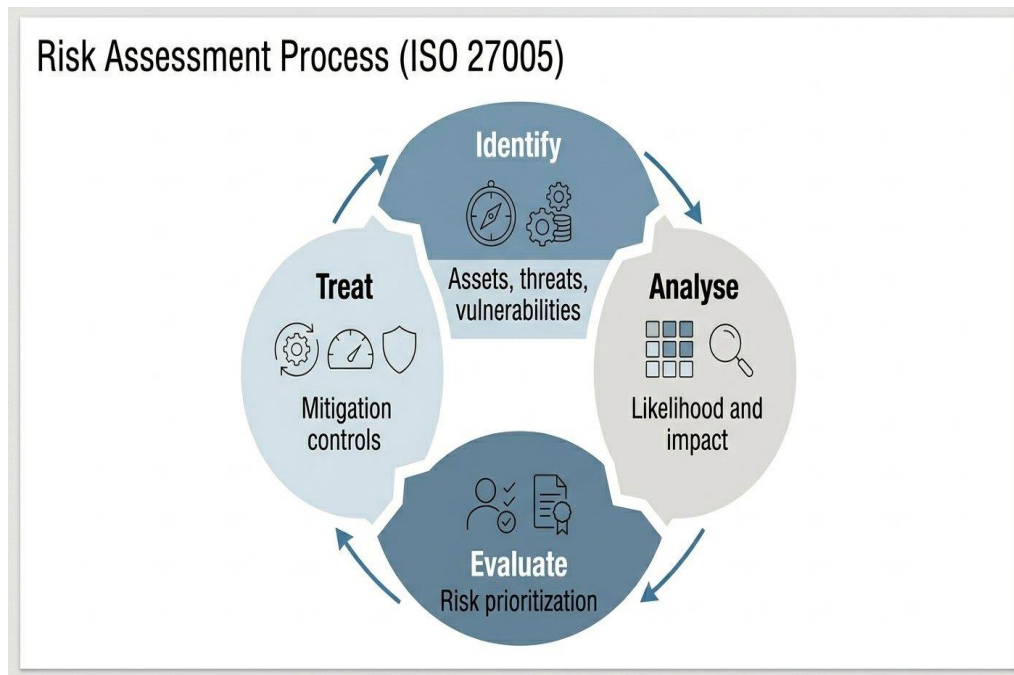


Figure 3.3 – Risk Assessment Process (ISO 27005:2022 Aligned)

3.4 Due Diligence Instruments

Due diligence instruments are standardised questionnaires used to gather structured information from vendors. The primary instruments used in TPRM practice are:

- SIG Questionnaire (Standardised Information Gathering): Developed by the Shared Assessments Program, the SIG covers 19 risk domains including access control, encryption, incident management, and business continuity. The SIG Lite is used for

initial screening; SIG Core for critical vendors. A 50-question DDQ aligned to SIG Lite principles was completed in the capstone project.

- CSA CAIQ (Consensus Assessment Initiative Questionnaire): Specifically designed for cloud service providers, aligned with the Cloud Controls Matrix (CCM). Covers cloud-specific domains including infrastructure security, encryption, IAM, logging, and application security. A CAIQ (Medium) assessment was completed in the capstone project.
- ISO/IEC 27001:2022 Annex A Based Checklists: Assess control coverage across all four control categories. A condensed Annex A mapping was completed in the capstone project to confirm organisational, people, physical, and technical control coverage.
- SOC 2 Type II Reports: Independent auditor reports providing assurance over security, availability, processing integrity, confidentiality, and privacy controls over a defined audit period. Key to TPRM due diligence in financial services engagements.
- Penetration Test Reports: Provide evidence of proactive vulnerability testing and remediation. Reviewed for scope, critical findings, and remediation timelines.

CHAPTER 4:

PROJECT MANAGEMENT

4.1 Foundation Training – Weeks 1 and 2

The first two weeks comprised a general technology and cybersecurity foundation training programme delivered over 12 days, ensuring all interns had a common technical baseline before progressing to the TPRM specialisation.

Day	Topic	Key Content
Day 1	Computer Hardware and OS Fundamentals	CPU, memory, storage, BIOS/UEFI, disk partitioning, file systems, OS components, Windows and Linux, virtual machines
Day 2	Networking Fundamentals	OSI/TCP-IP models, IP addressing, subnetting, DNS, DHCP, NAT, VPN, firewalls, routers
Day 3	System Administration	Windows/Linux user management, permissions, file sharing, system logs, troubleshooting
Day 4	Network Security Basics	Firewalls, IDS/IPS, common attacks and defences, antivirus vs EDR, SSH, RDP, patch management
Day 5	Cybersecurity Concepts	CIA Triad, threat actors, cryptography, security domains (network, application, endpoint, cloud), DLP
Day 6	Scripting and Tools	PowerShell basics, Linux CLI, cybersecurity threats overview, ServiceNow ticket lifecycle
	Milestone Assessment 1	End of Week 1
Day 7	Identity and Access Management	Identity, authentication, authorisation, AD/LDAP, SSO, MFA, privileged accounts
Day 8	Security Operations and Monitoring	SOC structure, logs and events, incident response, SIEM (ELK/Wazuh), MITRE ATT&CK

Day 9	Vulnerability and Patch Management	CVEs, CVSS scoring, patch lifecycle, scanning concepts (Nessus/OpenVAS), baseline validation
Day 10	Risk and Privacy Fundamentals	GRC introduction (ISO 27001, NIST CSF), risk treatment workflow, GDPR and DPDP Act overview, data classification
Day 11	Power BI, JIRA, Confluence	Power BI dashboards, data import and transformation; JIRA boards and sprint planning; Confluence SOPs and collaboration
Day 12	Integrated Case Study	Simulated incident in a multi-vendor EdTech environment — root cause analysis, impact assessment, group presentation
	Milestone Assessment 2	Technical 40%, Analytical 30%, Communication 20%, Documentation 10%

4.2 TPRM Specialisation Training – Weeks 3 to 8

From week three, training transitioned to TPRM-specific content. The table below summarises the key topics and learning outcomes for each week.

Week	Theme	Key Topics Covered
Week 3	Foundations of Enterprise Risk, TPRM and GRC	Three Lines of Defence model; ERM and GRC interaction; ISO 27001 Annex A.5, A.6, A.15; ISO 27701 for PII processor oversight; risk taxonomy and control themes; vendor lifecycle framework end-to-end; key TPRM artefacts (risk register, RACI, assessment checklists); GRC tool integration (Archer, ServiceNow VRM, MetricStream)
Week 4	Vendor Risk Assessment and Due Diligence	Risk assessment stages (ISO 27005/31000); SIG Lite, SIG Core, CSA CAIQ, ISO-based checklists; due diligence documentation review (SOC 2 Type II, penetration test reports, ISO certificates); criticality and residual risk scoring; risk matrix methodology; control

		testing (access, encryption, DR, incident, DLP, cloud, logging); evidence validation techniques; automating response summaries using LLMs
Week 5	Continuous Monitoring and Performance Management	ISO 27001 Annex A.15 monitoring obligations; continuous monitoring framework layers (security, compliance, privacy, operational, financial); KRI and KPI design for suppliers; KRI cascading across vendor tiers; security rating platforms (BitSight, UpGuard, SecurityScorecard); SIEM/SOC integration for vendor event tracking; RAG reporting and escalation governance; AI use cases in monitoring (vendor behaviour anomaly detection)
Week 6	Risk Treatment and Contractual Governance	Risk treatment options under ISO 27001 Clause 8; supplier Statement of Applicability; risk treatment plan structure; remediation tracker design (Excel, Power BI, ServiceNow); contract components (GDPR/DPDP data protection clauses, right-to-audit, sub-processor approval); SLA governance (uptime, RTO/RPO, enforcement mechanisms); ISO 27701 PII processor obligations; governance review meetings and escalation protocols; executive risk summaries and RAG briefings
Week 7	Automation, Analytics and Integrated TPRM Operations	Centralised risk register design; GRC tools (ServiceNow VRM, Archer IRM, AuditBoard, Power BI); automation via Power Automate, Python, and RPA; KPI dashboards for executives; board-level reporting (heat maps, vendor tiering visuals, trend charts); predictive risk scoring using AI; continuous assurance concepts; audit evidence repositories and data pipelines; Power BI for continuous control validation
Week 8	Capstone Project	Full end-to-end TPRM engagement simulation: vendor identification and criticality assessment; ISO-aligned risk assessment and scoring; risk register and treatment plan; continuous monitoring framework and KRI design; audit

		evidence and executive summaries; findings presented to internal panel
--	--	--

4.3 Milestone Assessments and Timeline

Milestone	Week	Assessment Focus
1	Week 1	Hardware, networking, OS, cybersecurity basics, PowerShell/Linux CLI
2	Week 2	IAM, SOC, vulnerability management, GRC, Power BI, JIRA — multi-domain assessment
3	Week 3	3LoD model, ISO 27001 Annex A, vendor lifecycle framework, GRC integration
4	Week 4	Due diligence execution, residual risk scoring, control testing, evidence validation
5	Week 5	KRI/KPI design, continuous monitoring framework, security rating platform interpretation
6	Week 6	Risk treatment planning, contract drafting, SLA design, ISO 27701 obligations
7	Weeks 7–8	Full capstone engagement deliverables — end-to-end TPRM simulation

Figure 4.1 below illustrates the internship timeline across the six-month engagement.

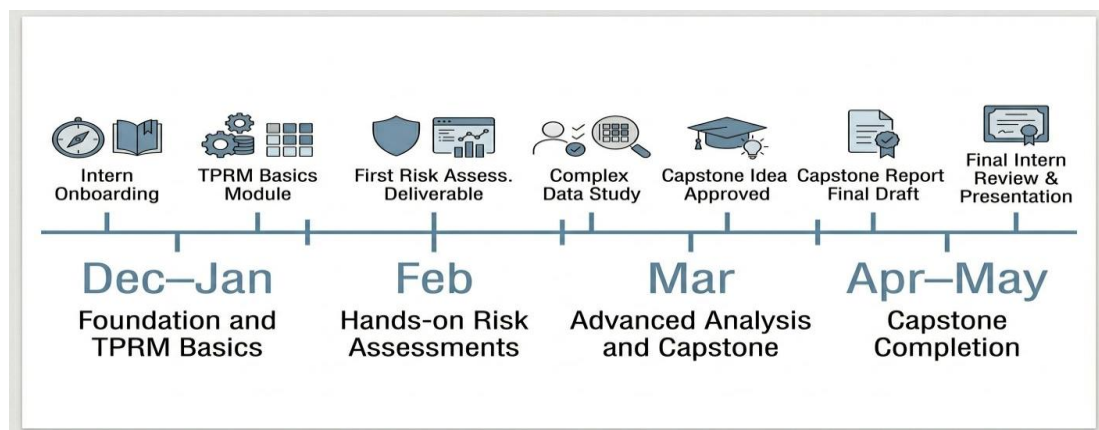


Figure 4.1 – Internship Timeline (December 2025 – May 2026)

CHAPTER 5:

ANALYSIS AND DESIGN

CAPSTONE TPRM ENGAGEMENT SIMULATION

5.1 Engagement Overview and Objectives

The capstone project was a full end-to-end TPRM engagement simulation, replicating the structure and deliverables of a real-world vendor risk assessment. All organisations, individuals, and data are entirely fictional and created for the purposes of the simulation.

Engagement scenario: Celestia National Bank Limited (the Bank) was migrating its Tier-1 Core Banking System and Mobile Banking Platform to a cloud hosting provider, replacing ageing on-premises infrastructure. Given the Tier-1 criticality of the workloads — encompassing core transaction processing, customer account management, mobile banking services, and payment gateway interfaces — a comprehensive TPRM assessment was required before vendor onboarding approval.

Engagement objectives: replace legacy infrastructure with a resilient, regulator-aligned cloud platform achieving minimum 99.95% availability (RTO under 2 hours, RPO under 15 minutes); strengthen security posture (AES-256, TLS 1.3, BYOK, PAM, quarterly pen-tests); ensure India data residency and regulator audit rights; and establish a continuous monitoring framework with defined KRIs.

Figure 5.1 below illustrates the three-phase structure of the capstone engagement.

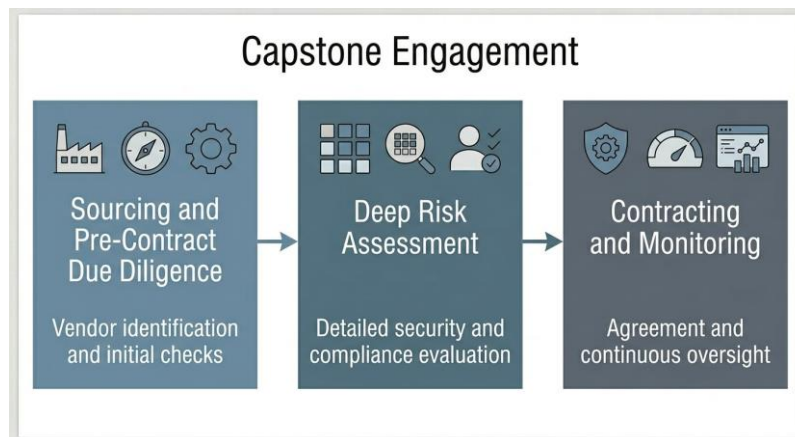


Figure 5.1 – Capstone Engagement – Three Phase Structure

5.2 Criticality Assessment

Parameter	Assessment	Rationale
Vendor Tier	Tier 1 (Critical)	Hosts core transaction processing — direct impact on banking operations
Data Classification	Confidential / PII / Financial	Customer accounts, transaction records, mobile banking credentials
Regulatory Scope	High	RBI outsourcing guidelines, DPDP Act, PCI-DSS, ISO 27001 required
Access Level	Full administrative and data access	Cloud infrastructure management, database access, application hosting
Business Continuity Impact	Critical	Unplanned downtime directly impacts banking operations and regulatory SLAs
Geographical Requirement	India-based data centres required	Data residency obligation under DPDP Act
Sub-processor Risk	Medium-High	Cloud infrastructure likely to involve sub-processors for networking, CDN, monitoring

Based on the criticality assessment, the engagement was classified as Tier-1 high-complexity, requiring full SIG Core questionnaire, ISO 27001 Annex A mapping, SOC 2 Type II review, and comprehensive risk register with treatment plan.

5.3 Phase 1 – Sourcing and Pre-Contract Due Diligence

A structured RFI/RFP process identified and evaluated candidate vendors. Three hyperscaler-class cloud providers were initially shortlisted; two progressed to RFP stage: ApexNimbus Cloud Services and StratoSure Infrastructure.

A weighted evaluation framework assessed vendors across five categories:

Evaluation Category	Weighting	ApexNimbus	StratoSure
Security (Controls, Certifications)	35%	93/100	78/100
Disaster Recovery and Resilience	25%	91/100	82/100
Compliance and Regulatory Alignment	20%	88/100	80/100
Operations and Service Delivery	10%	85/100	84/100
Financial Stability and Commercials	10%	79/100	81/100
Weighted Total Score	100%	89.9/100	80.1/100

ApexNimbus was selected as Preferred Vendor based on superior performance in the highest-weighted categories. Key differentiators included BYOK/HSM, active-active DR with RTO under 2 hours and RPO under 15 minutes, quarterly penetration testing, and ISO 27001:2022, ISO 22301, ISO 27701, SOC 1, and SOC 2 Type II certifications. While StratoSure offered marginally better commercials, the Bank prioritised control strength and regulatory alignment over nominal cost differences, consistent with Tier-1 weighting.

Phase 1 Category	Summary
Scope and Criticality	Business requirement, data classification, regulatory impact, and Tier-1 criticality confirmed
Market Scan	Hyperscaler-class cloud providers shortlisted on resilience, certifications, and financial stability
RFI to RFP Process	Three vendors responded to RFI; two (ApexNimbus and StratoSure) progressed to RFP

Down-Selection	Weighted evaluation favoured ApexNimbus on Security, DR, and Compliance — selected as Preferred Vendor
----------------	--

5.4 Phase 2 – Deep Risk Assessment

Due Diligence Instruments

Instrument	Scope	Outcome
DDQ – 50 Questions (SIG Lite aligned)	Security, compliance, operations, privacy	Completed — full ApexNimbus responses received
CAIQ (Medium)	Cloud-specific security domains	Completed — responses received and reviewed
ISO 27001:2022 Annex A (Condensed)	Organisational, people, physical, technical controls	Control coverage confirmed across all four categories
Evidence Validation Sheet	Encryption, DR, SOC2, ISO certs, PAM, patch KPIs, DLP	Consolidated proof reviewed; 5 open evidence items identified

Control Testing Summary

Control testing was conducted across eight security domains. Key findings were:

- Encryption and Key Management: AES-256 at rest, TLS 1.3 in transit, BYOK/HSM confirmed. All evidence provided — no gaps.
- Access Management: PAM with JIT access and session capture confirmed; MFA enforced for all privileged accounts. PAM session capture clip pending as open item.
- Disaster Recovery: Active-Active architecture confirmed; RTO under 2 hours, RPO under 15 minutes; semi-annual DR drills evidenced.
- Vulnerability Management: Quarterly third-party pen-testing confirmed; patch compliance KPIs tracked monthly. Patch ticket proof pending.
- Incident Management: 24-hour notification SLA documented; RCA within 5 business days; ITIL-aligned process confirmed.

- Data Protection and DLP: India-only data residency confirmed; DLP controls in place; sub-processor list provided. Anonymised DLP event log pending.
- Logging and Monitoring: SIEM with 180-day hot log retention and 1-year archive; 24/7 SOC/NOC operation confirmed.
- Certifications: ISO 27001:2022, ISO 22301, ISO 27701, SOC 1, SOC 2 Type II, PCI-DSS Level 1 infrastructure — all validated. DNSSEC screenshot pending.

5.5 Risk Register and Treatment Plan

The due diligence assessment produced a risk register with ten identified risks. Inherent risk was scored using a likelihood-impact model; residual risk reflects the post-treatment position following implementation of the treatment actions below.

Risk ID	Risk Description	Domain	Inherent Risk	Residual Risk
R01	PAM session capture evidence not yet provided — privileged access controls not fully verifiable	Access Management	High	Medium
R02	Anonymised DLP event log not submitted — DLP operational effectiveness unconfirmed	Data Protection	Medium	Low
R03	Patch ticket proof pending — patch compliance KPI not evidenced	Vuln. Management	Medium	Low
R04	CI/CD pipeline log not provided — software supply chain security unverified	App. Security	High	Medium
R05	DNSSEC screenshot not submitted — DNS security posture unconfirmed	Infrastructure	Medium	Low

R06	Credit rating confirmation pending — financial stability not independently verified	Financial	Low	Low
R07	Sub-processor annual re-review process not yet contractually formalised	Contractual/Privacy	High	Medium
R08	Chain-of-custody for evidence artefacts not formalised in contract	Contractual	Medium	Low
R09	Exit data portability lacks explicit crypto-shred confirmation mechanism	Operational/Contractual	High	Medium
R10	Monitoring not yet automated — manual RAG introduces execution risk	Operational	Medium	Low

Figure 5.2 below shows the risk heat map plotting all ten identified risks by inherent likelihood and impact.

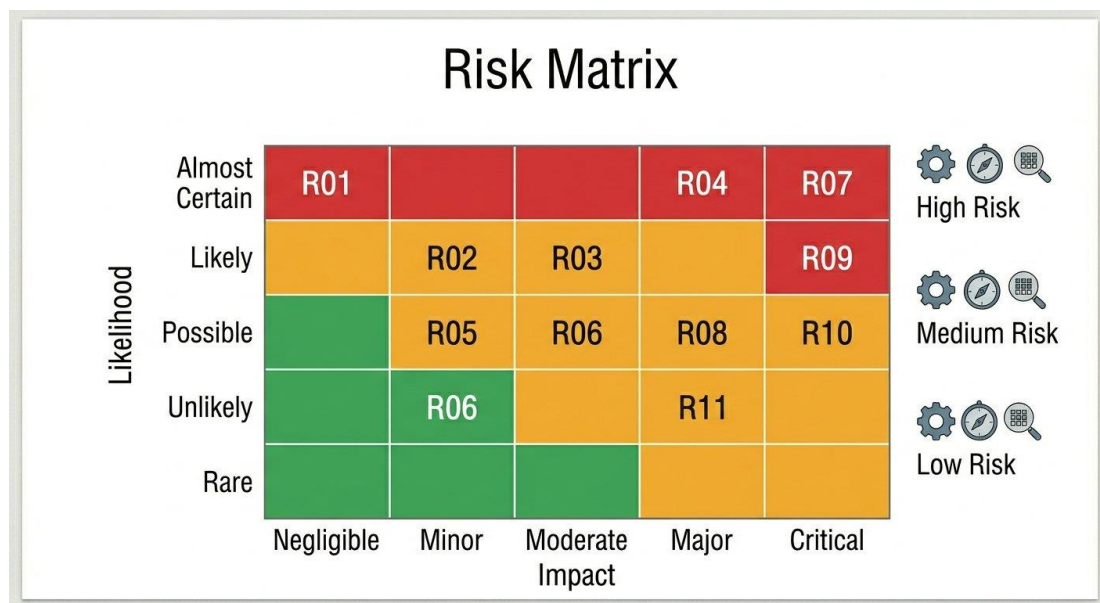


Figure 5.2 – Risk Matrix – Capstone Engagement (10 Identified Risks)

Risk ID	Treatment	Action	Owner	Timeline
R01	Mitigate	Provide redacted PAM session capture clip	ApexNimbus Security Lead	14 days
R02	Mitigate	Submit anonymised DLP event log (90-day period)	ApexNimbus DLP Team	14 days
R03	Mitigate	Provide anonymised patch ticket proof	ApexNimbus Operations	14 days
R04	Mitigate	Submit sanitised CI/CD pipeline log	ApexNimbus DevSecOps	21 days
R05	Mitigate	Submit DNSSEC configuration screenshot	ApexNimbus Infrastructure	7 days
R06	Accept	Obtain credit rating issuer confirmation and file	Bank Procurement	30 days
R07	Contractual	Embed Annual Sub-processor Review clause in DPA	Legal / Contracting	At signing
R08	Contractual	Embed Chain-of-Custody clause in MSA	Legal / Contracting	At signing
R09	Contractual	Include crypto-shred (NIST 800-88) in exit provisions	Legal / Contracting	At signing
R10	Mitigate	Implement KRI dashboard (manual RAG; automate within 90 days)	Bank TPRM Team	90 days post-go-live

5.6 Phase 3 – Contracting and Monitoring Framework

Contract Framework

Instrument	Key Provisions
MSA	36-month term (2×12 renewal); liability cap 12× MRC; unlimited liability for data breach, fraud, gross negligence; right-to-audit; chain-of-custody clause; quarterly performance reviews; service credit regime
DPA	India-only data residency; AES-256/TLS 1.3; BYOK/HSM; data subject assistance; sub-processor pre-approval and annual review; flow-down obligations; 72-hour breach notification; GDPR Article 28 and DPDP Act aligned
SLA	Compute 99.99%, Storage 99.999%, DB 99.95% uptime; RTO under 2 hours; RPO under 15 minutes; 24-hour incident notification; RCA within 5 business days; full audit support; SOC 2 Type II and ISO certs annually

Exit Strategy

The contract included: data portability in open formats (SQL/CSV/Parquet, OVA/OVF/VHD, IaC exports); 12-month transition support post-termination with dual-running readiness; crypto-shred per NIST 800-88 with Certificates of Destruction; and final acceptance criteria requiring zero residual data, all access revoked, and complete evidence pack submitted.

Ongoing Monitoring Framework

KRI	Frequency	Red Threshold
Monthly uptime vs SLA commitment	Monthly	Below 99.95%
DR drill success — RTO/RPO adherence	Semi-annual	RTO above 2h or RPO above 15min
Patch compliance rate vs KPI target	Monthly	Below 90%
Incident notification SLA adherence	Per incident	Any breach of 24-hour SLA

Unresolved DLP events	Monthly	Any event unresolved after 30 days
Privileged access anomalies (PAM)	Monthly	Anomaly unresolved after 7 days
Unapproved sub-processor changes	Continuous	Any unapproved change implemented
Certificate currency (SOC 2, ISO)	Quarterly	Any cert expired or scope reduced
Remediation action closure rate	Monthly	Actions overdue by 30+ days

Monitoring cadence: monthly SLA and security reviews; quarterly QBRs covering DR readiness, security posture, and operational performance; semi-annual DR drills; annual certification and contractual obligations reviews.

5.7 Final Recommendation

Decision: Approve onboarding of **ApexNimbus Cloud Services** for Tier-1 Core and Mobile Banking workloads, subject to: (1) completion of all 10 Risk Treatment Plan actions; (2) activation of the Ongoing Monitoring Framework; and (3) inclusion of exit strategy provisions (12-month support, crypto-shred per NIST 800-88) in the final contract.

Residual risk conclusion: No critical control gaps remain. Residual exposure is limited and manageable within the Bank's Tier-1 risk appetite. Decision recorded as: Approve with Conditions.

CHAPTER 6:

SOFTWARE AND TOOLS

6.1 Tools Studied During Training

The following enterprise platforms were covered during the structured training programme. These represent the standard technology stack used in professional TPRM and GRC practice. Exposure during training was conceptual and demonstration-based.

GRC and TPRM Platforms

- ServiceNow VRM: Cloud-based platform for automating the full vendor risk lifecycle — questionnaire distribution, risk register management, remediation tracking, and real-time portfolio dashboards.
- Archer IRM (RSA Archer): Enterprise GRC platform with customisable risk scoring models, evidence collection workflows, control gap mapping, and remediation tracking. Covered in the context of TPRM programme management.
- MetricStream and AuditBoard: GRC platforms covering risk management, compliance management, and audit management. Covered conceptually for workflow routing and audit evidence repository management.

Security Rating Platforms

- BitSight: Continuously monitors organisations' external-facing digital infrastructure, generating security ratings based on observable signals (open vulnerabilities, patching cadence, leaked credentials). Used as a continuous external risk indicator for vendors in TPRM programmes.
- UpGuard and SecurityScorecard: Similar external attack surface monitoring platforms providing vendor risk intelligence and security ratings across multiple domains including network security, endpoint security, and patching cadence.

SIEM and Analytics Tools

- Microsoft Sentinel and Wazuh: SIEM platforms covered for vendor incident correlation — mapping vendor-reported incidents to internal risk dashboards — and for log management and event detection in security operations.
- Microsoft Power BI: Business intelligence platform covered for building risk dashboards, KRI monitoring reports, and vendor performance dashboards. Applied in both Week 2 foundation training and Week 7 automation training.
- Microsoft Power Automate and Python: Covered for designing automated TPRM workflows — including reminders for document expiry, SLA breach alerts, and automated risk scoring calculations.

6.2 Tools Applied in the Capstone Project

- Microsoft Excel: Primary working tool throughout the capstone. Used for the 50-question DDQ, risk register (10 risks with inherent and residual scoring), risk treatment plan tracker, KRI monitoring framework, and evidence validation sheet.
- Microsoft Word: Used for drafting the Final Executive Report — including executive summary, engagement objectives, phase summaries, risk findings, final recommendation, and approvals section.
- SIG Lite DDQ Template (Excel-based): Custom 50-question questionnaire aligned to SIG Lite principles, covering all primary control domains.
- CSA CAIQ Template (Excel-based): Standard CSA questionnaire format adapted for the ApexNimbus cloud service scope.
- ISO 27001:2022 Annex A Mapping Workbook (Excel-based): Condensed control mapping workbook covering all four Annex A control categories for the vendor assessment.

CHAPTER 7:**EVALUATION AND RESULTS****7.1 Control Domain Scoring Summary**

Control Domain	Controls Assessed	Controls Satisfied	Open Items	Score	RAG
Encryption and Key Management	8	8	0	100%	Green
Access and Identity Management	10	8	2	80%	Amber
Disaster Recovery and Resilience	7	7	0	100%	Green
Vulnerability and Patch Management	6	5	1	83%	Amber
Incident Management	5	5	0	100%	Green
Data Protection and DLP	8	7	1	88%	Amber
Logging and Monitoring	5	5	0	100%	Green
Certifications and Compliance	6	5	1	83%	Amber
Overall Weighted Score	55	50	5	91%	Amber – Acceptable with Conditions

All five open items were evidence-level gaps — pending documentary submissions — rather than fundamental control failures. No critical control deficiencies were identified. The overall weighted score of 91% placed the vendor in the Acceptable with Conditions risk band.

7.2 Residual Risk Conclusion

- High Residual Risks: 0 (nil)
- Medium Residual Risks: 4 (R01, R04, R07, R09 — all pending evidence or contractual actions during onboarding)
- Low Residual Risks: 6 (R02, R03, R05, R06, R08, R10 — all tractable and time-bound)

Formal conclusion: No critical control gaps remain. Residual exposure is limited and manageable within the Bank's Tier-1 risk appetite, subject to completion of all ten risk treatment actions.

7.3 Final Recommendation Summary

The Final Executive Report presented the following formal recommendation: Approve onboarding of ApexNimbus with conditional closure of remaining treatment actions during contracting and onboarding. Conditions: (1) completion of outstanding evidence submissions; (2) activation of KRI monitoring framework from go-live; (3) inclusion of exit provisions in final contract. Decision: Approve with Conditions. Required approvals: Head TPRM, CISO, CRO, CIO, and Procurement Head.

7.4 KRI Dashboard

KRI	Green	Amber	Red
Monthly uptime vs SLA	Above 99.99%	99.95%–99.99%	Below 99.95%
RTO (DR Drills)	Under 1.5h	1.5–2h	Above 2h
RPO (DR Drills)	Under 10 min	10–15 min	Above 15 min
Patch Compliance Rate	Above 95%	90%–95%	Below 90%
Incident Notification SLA	100% on-time	1–2 late per quarter	Any breach over 24h
Unresolved DLP Events	Zero	Under investigation within 30 days	Unresolved after 30 days

PAM Anomalies	Zero	Under investigation within 7 days	Unresolved after 7 days
Sub-processor Changes	Zero unapproved	Pre-notification received	Unapproved change implemented
Certificate Currency	All valid and in scope	Expiry within 60 days	Expired or scope reduced

Figure 7.1 below shows the Vendor Performance Dashboard presenting all KRIs in RAG format, structured across four reporting sections: Uptime and SLA Performance, Patch and Security Events, Security Events, DR Readiness, and Contract Obligations.

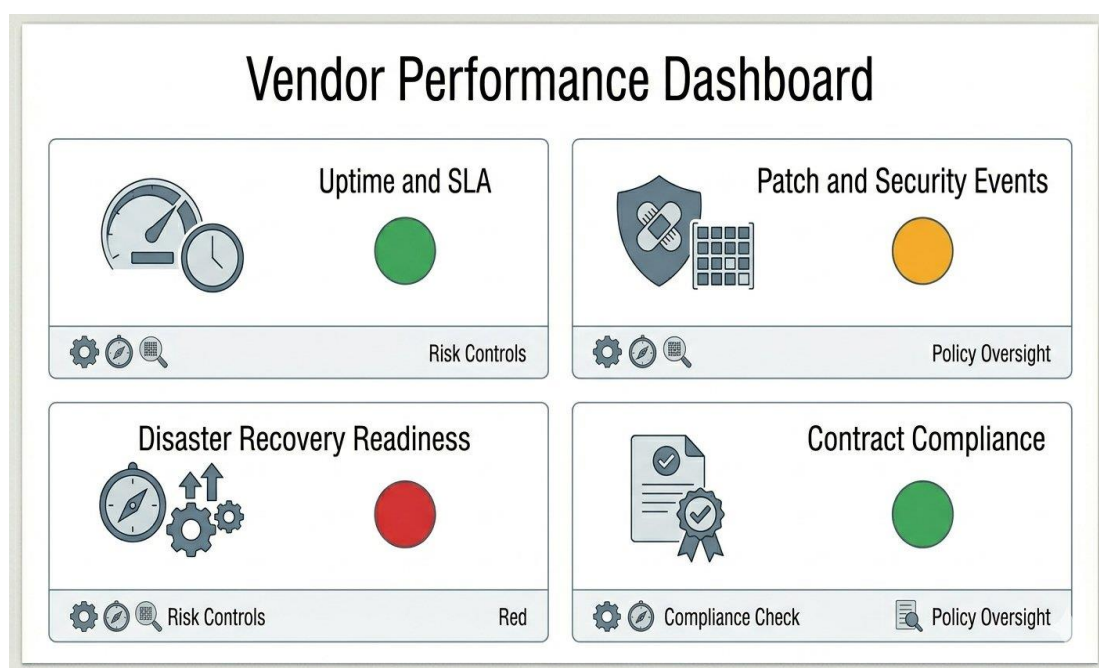


Figure 7.1 – Vendor Performance Dashboard – KRI Summary (RAG Format)

CHAPTER 8:

SOCIAL, LEGAL, ETHICAL AND SUSTAINABILITY ASPECTS

8.1 Social Aspects

TPRM directly protects the social integrity of digital service delivery. In the banking sector, a failure by a critical cloud vendor can disrupt customer access to accounts, payments, and essential financial services. Effective TPRM reduces the likelihood and impact of such disruptions, protecting customers and communities. At a broader level, TPRM contributes to digital trust — the confidence that individuals and organisations can place in digital ecosystems. The internship also contributed socially by developing a skilled, ethically grounded risk professional for the Indian digital economy.

8.2 Legal Aspects

GDPR (Article 28) requires that all data processing by third-party processors be governed by a written Data Processing Agreement. India's DPDP Act (2023) establishes equivalent obligations for data fiduciaries and processors, requiring data minimisation, purpose limitation, security safeguards, and breach notification. ISO 27001 certification places vendors under surveillance audit obligations. RBI outsourcing guidelines impose explicit requirements on banks regarding vendor governance, contractual provisions, and data localisation. All four instruments directly informed the DPA, MSA, and SLA design in the capstone project.

8.3 Ethical Aspects

TPRM raises important ethical considerations. Data privacy and confidentiality require that vendor-provided information — security configurations, audit reports, operational data — be used solely for risk assessment purposes and handled with appropriate confidentiality. Fairness in risk scoring requires that judgements be based on objective, evidence-based criteria consistently applied. In the KPMG context, adherence to firm-wide confidentiality policies was mandatory; all capstone deliverables used exclusively fictional data. The emerging use of AI in TPRM raises additional ethical considerations around transparency, human oversight, and bias in AI-driven risk models.

8.4 Sustainability Aspects

TPRM intersects with sustainability through ESG governance — the training curriculum introduced ESG considerations in vendor risk assessments, including vendors' environmental practices (data centre energy efficiency) and social practices (labour standards). TPRM contributes to digital sustainability by identifying and treating concentration risks and resilience vulnerabilities in vendor ecosystems, reducing the likelihood of systemic disruptions with lasting economic and social consequences. Responsible TPRM practice also supports sustainable vendor partnerships through transparent communication and constructive remediation engagement.

8.5 Safety Aspects

TPRM directly addresses cybersecurity safety by ensuring vendors implement adequate security controls — covering access management, encryption, vulnerability management, incident response, and DLP. By requiring vendors to demonstrate robust DR capabilities (RTO, RPO, DR drill evidence), TPRM contributes to operational safety and resilience. Evidence validation processes protect the organisation from reliance on inaccurate or fraudulent vendor documentation, ensuring the safety and integrity of information upon which risk decisions are based.

CHAPTER 9:

CONCLUSION

The six-month internship at KPMG Global Services, Bengaluru, provided a rigorous, structured, and professionally enriching introduction to Third Party Risk Management. The programme progressed logically from foundational cybersecurity and technical knowledge, through advanced TPRM frameworks and methodologies, to a comprehensive capstone engagement simulation — providing both theoretical depth and practical application across the discipline.

The two-week foundation training established the technical baseline necessary to engage meaningfully with vendor control assessments — providing functional knowledge of networking, IAM, security operations, vulnerability management, and GRC fundamentals. The six-week TPRM specialisation then built upon this foundation comprehensively: from the governance model and vendor lifecycle framework, through risk assessment methodology, due diligence instrumentation, residual risk scoring, and contractual governance, to continuous monitoring design and automation in TPRM operations.

The capstone project was the most significant learning outcome of the internship. Conducting a full end-to-end TPRM engagement simulation — producing a DDQ, CAIQ, ISO Annex A mapping, risk register, risk treatment plan, MSA/DPA/SLA framework, KRI monitoring design, and executive report for a fictional Tier-1 banking engagement — provided concrete evidence of competency across the full spectrum of TPRM professional practice. The simulation required independent judgement in risk scoring, treatment selection, and contractual design, reflecting the real-world demands of TPRM work at a Big Four firm.

Key professional competencies developed through this internship include proficiency in the vendor lifecycle framework; hands-on due diligence using SIG, CAIQ, and ISO Annex A instruments; inherent and residual risk scoring using likelihood-impact models; risk register and treatment plan management; MSA, DPA, and SLA design incorporating GDPR, DPDP Act, and ISO 27701 requirements; KRI-based continuous monitoring framework design; and

executive risk reporting in RAG format. These competencies are directly applicable to careers in cybersecurity, GRC, and risk management in the financial services sector and beyond.

In conclusion, the internship at KPMG Global Services was a deeply formative professional experience. The structured, progressive nature of the training programme, combined with the rigour of the capstone project, has significantly strengthened readiness for a career in third-party risk management, information security governance, and enterprise risk advisory.

REFERENCES

- [1] International Organisation for Standardisation. (2022). ISO/IEC 27001:2022 – Information Security Management Systems – Requirements. ISO.

- [2] International Organisation for Standardisation. (2022). ISO/IEC 27005:2022 – Guidance on Managing Information Security Risks. ISO.

- [3] International Organisation for Standardisation. (2018). ISO 31000:2018 – Risk Management – Guidelines. ISO.

- [4] International Organisation for Standardisation. (2019). ISO/IEC 27701:2019 – Extension to ISO 27001 and 27002 for Privacy Information Management. ISO.

- [5] International Organisation for Standardisation. (2019). ISO 22301:2019 – Business Continuity Management Systems – Requirements. ISO.

- [6] National Institute of Standards and Technology. (2024). NIST Cybersecurity Framework (CSF) 2.0. U.S. Department of Commerce. <https://www.nist.gov/cyberframework>

- [7] National Institute of Standards and Technology. (2012). NIST Special Publication 800-88 Rev. 1 – Guidelines for Media Sanitisation. U.S. Department of Commerce.

- [8] European Parliament. (2016). Regulation (EU) 2016/679 – General Data Protection Regulation. Official Journal of the European Union.

- [9] Government of India. (2023). The Digital Personal Data Protection Act, 2023. Ministry of Electronics and Information Technology.

- [10] Shared Assessments Program. (2024). Standardised Information Gathering (SIG) Questionnaire – Core and Lite. Shared Assessments.
- [11] Cloud Security Alliance. (2023). Consensus Assessments Initiative Questionnaire (CAIQ) v3.1. <https://cloudsecurityalliance.org>
- [12] Cloud Security Alliance. (2023). Cloud Controls Matrix (CCM) v4. Cloud Security Alliance.
- [13] Payment Card Industry Security Standards Council. (2022). PCI DSS v4.0. PCI SSC.
- [14] Reserve Bank of India. (2023). Master Direction – Outsourcing of Financial Services. <https://www.rbi.org.in>
- [15] KPMG International. (2024). Third Party Risk Management: Trends and Emerging Practices. KPMG Advisory.
- [16] Deloitte. (2024). The Extended Enterprise Risk Management Survey. Deloitte Insights.
- [17] Gartner. (2024). Market Guide for Third-Party Risk Management. Gartner Research.
- [18] BitSight Technologies. (2024). Security Ratings Methodology. <https://www.bitsight.com>
- [19] ServiceNow. (2024). Vendor Risk Management – Product Documentation. <https://www.servicenow.com>
- [20] MITRE Corporation. (2024). MITRE ATT&CK Enterprise Framework v14. <https://attack.mitre.org>

APPENDIX

Appendix A – Capstone Engagement Quick Reference

Parameter	Details
Engagement Title	TPRM Assessment: Cloud Hosting for Tier-1 Core and Mobile Banking
Client (Fictional)	Celestia National Bank Limited
Vendor Assessed (Fictional)	ApexNimbus Cloud Services
Engagement Type	New Vendor Onboarding – Tier 1 Critical
Workloads in Scope	Core Banking System, Mobile Banking Platform, Payment Gateway
Data Classification	Confidential, PII, Financial Transaction Data
Phases Covered	Phase 1: Sourcing; Phase 2: Deep Risk Assessment; Phase 3: Contracting and Monitoring
DD Instruments Used	DDQ (50 questions), CAIQ (Medium), ISO Annex A (Condensed), Evidence Validation Sheet
Risks Identified	10 risks (4 High inherent, 5 Medium, 1 Low)
Residual Risk	Acceptable with Conditions (0 High, 4 Medium, 6 Low)
Final Decision	Approve with Conditions

Appendix B – Note on Confidentiality

In accordance with KPMG Global Services' requirements communicated to all interns, this report contains no confidential, proprietary, or sensitive company information. All organisations, vendors, and data in the capstone sections are entirely fictional. This report has been reviewed and approved by the intern's Performance Manager, Mr. Alex Jaideep, confirming it contains no confidential information.